

Cryptography & Data Protection

Data in transit

- Client-to-API communication is intended to be protected by HTTPS/TLS 1.2+ in production (terminated by the hosting provider / reverse proxy).
- API-to-Plaid communication uses TLS provided by the Plaid API client.

Data at rest

- Consumer data stored in the application database resides in managed PostgreSQL.
- Encryption at rest is provided by the database/storage provider at the volume/disk layer (provider-managed).
- The application does not implement additional application-layer (object/column-level) encryption by default.

Key management

- Application secrets (JWT secret, Plaid secrets, DB connection strings) are stored securely:
 - local development: macOS Keychain via environment variables
 - production: hosting provider secret manager / environment variables
- Secrets are rotated if exposure is suspected.

Password handling

- User passwords are stored as salted bcrypt hashes.

Token handling

- Plaid access tokens are stored server-side and are never returned to the web client.
- JWT bearer tokens are used for API access and are stored client-side for development convenience.